

11.2 Maßnahmen zur Informationssicherheit

Informationssicherheit umfasst technische, organisatorische und personelle Maßnahmen zum Schutz von Daten und Systemen.

Technische Maßnahmen

Schützen IT-Systeme durch Hard- und Softwarelösungen.

- **Netzwerksicherheit:** Firewalls, Intrusion Detection/Prevention Systems (IDS/IPS)
- **Verschlüsselung:** TLS, AES, VPNs für sichere Kommunikation
- **Zugangskontrollen:** Biometrie, Zwei-Faktor-Authentifizierung (2FA)
- **Sicherheitsupdates:** Regelmäßige Patches und Aktualisierungen
- **Backups & Redundanz:** Regelmäßige Sicherungen, Georedundanz

Organisatorische Maßnahmen

Regeln und Prozesse zur Einhaltung von Sicherheitsrichtlinien.

- **ISMS (Information Security Management System):** Systematische Verwaltung der Informationssicherheit (z. B. nach ISO 27001)
- **Richtlinien & Schulungen:** Sicherheitsrichtlinien für Mitarbeiter, Awareness-Trainings
- **Zugriffsmanagement:** Rollen- und Rechtekonzepte (z. B. Least Privilege Principle)
- **Notfallmanagement:** Disaster Recovery Pläne, Incident Response

Personelle Maßnahmen

Mitarbeiter als Sicherheitsfaktor durch Sensibilisierung und Schulung.

- **Awareness-Programme:** Phishing-Tests, Schulungen zu Social Engineering
- **Verhaltensrichtlinien:** Klare Vorgaben zur Passwortsicherheit, Nutzung externer Geräte
- **Vertraulichkeitsvereinbarungen:** NDA, Geheimhaltungsvereinbarungen

[11.3 Technisch-organisatorische Maßnahmen](#)